Plano de Aulas: Fundamentos de Segurança de Softwares (2026)

Ano de Escolaridade: 3º Ano | **Carga Horária Semanal:** 1 aula (Quinta-feira)

Primeiro Trimestre (13 Aulas)

Período do Trimestre: 04/02/2026 a 20/05/2026

"05/02 a 13/02": Semana 01 - Introdução à Segurança da Informação *Nota: A semana letiva inicial possui duas quintas-feiras, logo foi desdobrada na contagem (Semana 01 e Semana 02).* Conteúdo: Tríade CIA (Confidencialidade, Integridade e Disponibilidade); Autenticidade e Irretratabilidade. Atividades: Realização de um debate aprofundado sobre casos reais e notórios de vazamento de dados corporativos e governamentais, focando na análise crítica do impacto direto nos três pilares fundamentais da segurança da informação (CIA). Os alunos deverão produzir um breve relatório reflexivo sobre as medidas preventivas que poderiam ter evitado tais incidentes. Data da aula: 05/02

"05/02 a 13/02": Semana 02 - A Cartilha de Segurança para Internet Conteúdo: Riscos na rede; Códigos maliciosos (Malware); Spam e Phishing. Atividades: Condução de um estudo dirigido e interativo utilizando a Cartilha de Segurança para Internet (CGI.br), onde os alunos trabalharão em grupos para mapear, identificar e apresentar os principais vetores de ataque comuns na atualidade. A atividade culminará na criação de um mapa mental colaborativo que ilustra as relações entre diferentes tipos de malwares e vulnerabilidades. Data da aula: 12/02

"23/02 a 27/02": Semana 03 - Ameaças e Vulnerabilidades Conteúdo: Diferença entre ameaça, vulnerabilidade e risco; Ativos de informação. Atividades: Desenvolvimento de uma simulação prática baseada na construção de um cenário empresarial fictício. Os alunos atuarão como consultores de segurança, realizando o mapeamento completo dos ativos de informação tecnológicos da empresa. Em seguida, deverão catalogar exaustivamente as vulnerabilidades associadas a cada ativo e propor um plano de mitigação inicial. Data da aula: 26/02

"02/03 a 06/03": Semana 04 - Mecanismos de Segurança (Parte 1) Conteúdo: Controles lógicos; Criptografia Simétrica e Assimétrica. Atividades: Execução de uma oficina prática no laboratório de informática focada nos fundamentos da criptografia moderna. Os alunos utilizarão ferramentas de software para realizar exercícios de cifragem e decifragem de mensagens interceptadas, comparando empiricamente a eficiência, o desempenho e os casos de uso ideais para algoritmos de criptografia simétrica e assimétrica. Data da aula: 05/03

"09/03 a 13/03": Semana 05 - Mecanismos de Segurança (Parte 2) Conteúdo: Assinatura Digital e Certificados Digitais; Hash e Integridade. Atividades: Realização de um laboratório prático focado em integridade e autenticidade. Os alunos irão gerar, comparar e validar as assinaturas digitais de diferentes tipos de arquivos e documentos utilizando algoritmos de Hash (MD5, SHA-256). A atividade demonstrará na prática como garantir que um software não foi adulterado durante o download ou transferência na rede. Data da aula: 12/03

"23/03 a 27/03": Semana 06 - Fatores Essenciais para o Desenvolvimento Seguro *Nota: A semana anterior (16/03 a 20/03) foi pulada desta contagem, pois o dia da aula presencial foi Feriado de São José (19/03).* Conteúdo: Introdução ao ciclo de vida de desenvolvimento seguro (S-SDLC). Atividades: Comparativo detalhado em grupo entre metodologias de desenvolvimento ágil tradicionais e abordagens com foco na segurança desde o design (Security by Design). Os alunos elaborarão um quadro comparativo destacando as fases do S-SDLC (Secure Software Development Life Cycle) e como elas previnem retrabalho e vulnerabilidades em ambiente de produção. Data da aula: 26/03

"06/04 a 11/04": Semana 07 - Controle de Acesso e Privilégios *Nota: A semana de 30/03 a 03/04 foi pulada (Recesso na quinta-feira 02/04). Esta semana civil também engloba um Sábado Letivo, contando como Semana 07 e Semana 08.* Conteúdo: Autenticação, Autorização e Auditoria (AAA); Princípio do privilégio mínimo. Atividades: Laboratório de pesquisa envolvendo a configuração de matrizes de controle de acesso (RBAC - Role-Based Access Control). Os alunos deverão projetar regras de permissão seguindo rigorosamente o princípio do privilégio mínimo para diferentes perfis de utilizadores num ambiente de sistema de ficheiros simulado, documentando as políticas aplicadas. Data da aula: 09/04

"06/04 a 11/04": Semana 08 - AVALIAÇÃO 1 Conteúdo: Avaliação teórica sobre conceitos fundamentais, tríade da segurança e mecanismos básicos. Atividades: Aplicação de uma avaliação somativa teórica estruturada para mensurar a retenção de conhecimento sobre os pilares fundamentais da segurança da informação (CIA), a correta identificação de ameaças, vulnerabilidades e a aplicação teórica dos mecanismos básicos de proteção criptográfica discutidos intensamente nas aulas teóricas anteriores. Data da aula: 11/04 (Sábado Letivo de Quinta-Feira)

"13/04 a 17/04": Semana 09 - Práticas Seguras na Codificação (Parte 1) Conteúdo: Validação de inputs e saneamento de dados. Atividades: Desenvolvimento de um mini-projeto prático focado na validação de inputs e saneamento rigoroso de dados recebidos de utilizadores. A prática envolverá a refatoração de um formulário web vulnerável, onde os alunos deverão implementar filtros de segurança avançados para bloquear tentativas de ataques clássicos de Injeção de SQL e Cross-Site Scripting (XSS). Data da aula: 16/04

"20/04 a 24/04": Semana 10 - Práticas Seguras na Codificação (Parte 2) Conteúdo: Gestão segura de erros e exceções; Ocultação de stack traces. Atividades: Oficina de refatoração de código no laboratório com foco no tratamento e gestão segura de erros e exceções não tratadas. Os alunos analisarão logs de sistemas à procura de fugas de stack traces e informações sensíveis do servidor, reescrevendo o código para garantir que apenas mensagens de erro genéricas e seguras sejam exibidas ao utilizador final. Data da aula: 23/04

"27/04 a 01/05": Semana 11 - Gerenciamento Seguro de Sessão Conteúdo: Tokens de autenticação; Cookies seguros; Timeout de sessão. Atividades: Laboratório de desenvolvimento seguro onde os alunos deverão projetar e codificar um mecanismo robusto de controlo de sessão para uma aplicação web. A atividade exige a geração segura de tokens imprevisíveis, a

configuração de cookies com as flags HttpOnly e Secure, além da implementação de rotinas eficientes de timeout por inatividade do utilizador. Data da aula: 30/04

"04/05 a 08/05": Semana 12 - Métodos de Transferência de Arquivos Conteúdo: Protocolos seguros (SFTP, HTTPS, SCP); Vulnerabilidades em uploads. Atividades: Configuração e auditoria de um servidor de transferência de ficheiros, substituindo protocolos inseguros como o FTP padrão por alternativas robustas como SFTP e SCP. Os alunos também deverão criar regras de sanitização para uploads de ficheiros em sistemas web, bloqueando extensões perigosas e validando rigorosamente o MIME type real dos documentos. Data da aula: 07/05

"11/05 a 15/05": Semana 13 - Proteção de Dados Sensíveis Conteúdo: Armazenamento de senhas (Salting e Hashing); Mascaramento de dados. Atividades: Exercício prático de arquitetura de bases de dados visando a proteção absoluta de credenciais de utilizadores. Os alunos desenvolverão um script de backend que recebe passwords em texto plano e as armazena de forma segura utilizando técnicas modernas de hashing com salt aleatório (como BCrypt ou Argon2), debatendo ativamente a obsolescência do MD5. Data da aula: 14/05

Segundo Trimestre (13 Aulas)

Período do Trimestre: 21/05/2026 a 09/09/2026

"18/05 a 22/05": Semana 14 - Revisão do Código em Busca de Brechas Conteúdo: Técnicas de Code Review focadas em segurança; Checklist de vulnerabilidades. Atividades: Organização de uma dinâmica de "Peer Code Review" (revisão por pares) utilizando uma checklist padronizada de vulnerabilidades de software. Os alunos trocarão trechos de código criados em aulas anteriores e realizarão uma auditoria manual cruzada, simulando o papel de um analista de segurança (AppSec) na busca implacável por brechas de lógica e implementação. Data da aula: 21/05

"25/05 a 29/05": Semana 15 - AVALIAÇÃO 2 Conteúdo: Avaliação prática em laboratório: Correção de vulnerabilidades num código legado. Atividades: Execução de uma prova prática individual em ambiente de laboratório isolado. Os alunos receberão o código-fonte de um sistema legado propositadamente repleto de falhas de segurança (vulnerável a injeções, fugas de erros e falhas de sessão) e deverão refatorá-lo em tempo útil, entregando ao final uma versão segura, funcional e devidamente documentada. Data da aula: 28/05

"08/06 a 12/06": Semana 16 - Evitar Vulnerabilidades Externas (Parte 1) *Nota: A semana de 01/06 a 05/06 foi pulada, pois houve Recesso de Corpus Christi no dia reservado para nossa aula (04/06).* Conteúdo: Top 10 OWASP: Uma visão geral das principais vulnerabilidades web. Atividades: Estudo dirigido prático sobre o relatório OWASP Top 10 mais recente. Os alunos deverão analisar os relatórios técnicos e elaborar um quadro-resumo para cada uma das principais vulnerabilidades em aplicações web, descrevendo os vetores de ataque, as consequências gravosas para os negócios e as melhores práticas arquiteturais para mitigar estruturalmente esses riscos. Data da aula: 11/06

"15/06 a 19/06": Semana 17 - Evitar Vulnerabilidades Externas (Parte 2) Conteúdo: Ataques de Cross-Site Scripting (XSS) e Cross-Site Request Forgery (CSRF). Atividades: Laboratório

prático de exploração ética num ambiente controlado virtualizado (usando Kali Linux e máquinas propositadamente vulneráveis). Os alunos deverão executar simulações de ataques de Cross-Site Scripting (XSS) refletido e armazenado, além de explorar falhas de Cross-Site Request Forgery (CSRF), para logo em seguida aplicarem os devidos patches de correção. Data da aula: 18/06

"22/06 a 27/06": Semana 18 - Segurança em Redes e Sistemas Operacionais Conteúdo: Firewalls; Sistemas de Detecção de Intrusão (IDS/IPS). Atividades: Oficina de infraestrutura segura focada na proteção do perímetro do sistema operativo. Os alunos terão a incumbência de configurar regras restritivas em firewalls de host (como UFW ou iptables no Linux) para bloquear portas de rede desnecessárias e analisar alertas gerados por um Sistema de Detecção de Intrusões (IDS) perante um port scan simulado. Data da aula: 25/06

"29/06 a 03/07": Semana 19 - Vulnerabilidades em APIs e Web Services Conteúdo: Broken Object Level Authorization (BOLA); Fugas de dados em endpoints. Atividades: Auditoria de segurança e teste de penetração numa API RESTful de testes disponibilizada pelo docente. Os alunos utilizarão ferramentas da indústria (como Postman e Burp Suite) para identificar falhas de Broken Object Level Authorization (BOLA/IDOR), manipulando parâmetros de requisição para tentar aceder a dados privados, seguido da respetiva correção no backend. Data da aula: 02/07

"06/07 a 10/07": Semana 20 - Segurança na Camada de Transporte Conteúdo: SSL/TLS; Configuração de certificados em servidores web. Atividades: Prática intensiva de administração de servidores web focada na implementação de criptografia em trânsito. Os alunos deverão gerar chaves criptográficas, criar uma requisição de assinatura de certificado (CSR), configurar um certificado SSL/TLS autoassinado num servidor Nginx ou Apache e forçar o redirecionamento de todo o tráfego não encriptado (HTTP) para HTTPS. Data da aula: 09/07

"13/07 a 17/07": Semana 21 - Padrões de Segurança no Desenvolvimento (ISO/IEC 27034) Conteúdo: Normas internacionais para segurança de aplicações. Atividades: Estudo de caso guiado sobre a implementação prática das complexas normas internacionais da família ISO/IEC 27000 (com forte ênfase na 27034) em ambientes corporativos reais. Os alunos redigirão uma política de segurança de desenvolvimento simplificada para uma startup fictícia, englobando requisitos legais e de conformidade do setor tecnológico atual. Data da aula: 16/07

"03/08 a 07/08": Semana 22 - AVALIAÇÃO 3 Conteúdo: Projeto teórico-prático de análise de riscos numa arquitetura de software proposta. Atividades: Elaboração, submissão e apresentação de um projeto teórico-prático de análise estruturada de riscos. Com base numa arquitetura de software complexa fornecida previamente pelo professor, os alunos deverão identificar potenciais pontos únicos de falha, classificar o nível de risco das ameaças encontradas e propor um plano de mitigação arquitetural completo e exequível. Data da aula: 06/08

"10/08 a 14/08": Semana 23 - Testes Exaustivos por Atores Externos Conteúdo: Introdução ao Pentest (Teste de Intrusão); Tipos de teste (Black, Grey e White Box). Atividades: Planeamento estratégico detalhado de um escopo formal de Teste de Intrusão (Pentest). Os alunos documentarão as Regras de Engajamento (Rules of Engagement), definirão a diferença

clara de abordagem entre os testes Black Box, Grey Box e White Box para uma aplicação alvo, e criarão um cronograma de testes rigorosamente alinhado com as expectativas de um cliente. Data da aula: 13/08

"17/08 a 21/08": Semana 24 - Ferramentas de Teste de Vulnerabilidades Conteúdo: Utilização de scanners automatizados; Ferramentas do Kali Linux. Atividades: Sessão de laboratório prático totalmente focada no reconhecimento e mapeamento da superfície de ataque utilizando as ferramentas nativas do ecossistema Kali Linux. Os alunos conduzirão varreduras automatizadas de portas e descoberta de serviços ativos usando Nmap, seguidas da execução de scanners de vulnerabilidades web para identificar potenciais portas de entrada no sistema. Data da aula: 20/08

"24/08 a 28/08": Semana 25 - Análise Estática e Dinâmica (SAST/DAST) Conteúdo: Ferramentas de análise de código em tempo de escrita e execução. Atividades: Integração de camadas de segurança na esteira de desenvolvimento contínuo (DevSecOps) através da aplicação prática de ferramentas de análise de código estático (SAST). Os alunos executarão análises automatizadas num projeto de média dimensão em PHP ou Java, interpretarão os falsos positivos reportados pela ferramenta e procederão à correção imediata das vulnerabilidades. Data da aula: 27/08

"31/08 a 04/09": Semana 26 - Engenharia Social e o Fator Humano Conteúdo: Técnicas de manipulação; Conscientização de segurança. Atividades: Dinâmica em grupo envolvendo a conceção estratégica de campanhas simuladas de Phishing e manipulação psicológica (Engenharia Social). O objetivo fundamental é demonstrar na prática que o elo mais vulnerável da segurança da informação é o utilizador, finalizando a aula com a criação de um material gráfico de consciencialização em segurança digital voltado para funcionários. Data da aula: 03/09

Terceiro Trimestre (14 Aulas)

Período do Trimestre: 10/09/2026 a 18/12/2026

"07/09 a 12/09": Semana 27 - Plano de Resposta a Incidentes Conteúdo: O que fazer após um ataque; Investigação e contenção. Atividades: Realização de um imersivo "Tabletop Exercise" (simulação de mesa) de alta pressão, onde a turma será dividida em equipas de resposta a incidentes (Blue Team). Eles receberão um cenário simulado de um ataque devastador por Ransomware em progresso e deverão tomar decisões críticas e imediatas sobre contenção na rede, erradicação da ameaça, comunicação e recuperação. Data da aula: 10/09

"14/09 a 19/09": Semana 28 - Continuidade de Negócios e Backup Conteúdo: Estratégias de backup (3-2-1); Recuperação de desastres (DRP). Atividades: Desenvolvimento prático de um plano sólido de resiliência e recuperação de desastres (DRP). Os alunos escreverão, testarão e otimizarão scripts automatizados (em bash script ou Python) para realizar backups incrementais de bases de dados vitais, aplicando rigorosamente a regra 3-2-1 de backups, e incluirão mecanismos de verificação de hash para garantir a integridade da cópia guardada. Data da aula: 17/09

"21/09 a 24/09": Semana 29 - Segurança em Ambientes de Nuvem (Cloud Security) Conteúdo: Responsabilidade compartilhada; Segurança em containers (Docker). Atividades: Laboratório avançado focado exclusivamente em Cloud Security e conteinerização segura de aplicações. Os alunos irão analisar minuciosamente ficheiros Dockerfile à procura de más práticas (como executar serviços internos como root), realizarão varreduras de vulnerabilidades em imagens Docker e aplicarão conceitos de menor privilégio na orquestração de microserviços. Data da aula: 24/09

"28/09 a 02/10": Semana 30 - AVALIAÇÃO 4 Conteúdo: Avaliação prática: Auditoria completa de um pequeno sistema e geração de relatório de vulnerabilidades. Atividades: Realização de uma auditoria de segurança completa, exaustiva e totalmente autónoma sobre um pequeno sistema web de gestão fornecido pelo docente. Os alunos aplicarão todas as técnicas ofensivas aprendidas, explorarão as vulnerabilidades documentando o passo a passo (PoC) e gerarão um Relatório Executivo e Técnico de Vulnerabilidades com recomendações de mitigação cristalinas. Data da aula: 01/10

"05/10 a 09/10": Semana 31 - PROJETO FINAL: Definição de Políticas de Segurança Conteúdo: Planeamento do Laboratório de Segurança (Projeto Integrador). Atividades: Início oficial do Projeto Integrador de Laboratório de Segurança. Nesta fase embrionária, as equipas deverão delimitar rigorosamente o escopo do projeto de software a ser construído ou auditado, redigindo o documento inicial de Políticas de Segurança, estabelecendo requisitos não-funcionais de proteção de dados e definindo o fluxo seguro de desenvolvimento que será mantido. Data da aula: 08/10

"19/10 a 23/10": Semana 32 - PROJETO FINAL: Modelagem de Ameaças e Matriz de Riscos *Nota: A semana do dia 12/10 a 16/10 foi pulada da contagem em virtude dos recessos escolares listados em calendário.* Conteúdo: Threat Modeling e identificação de superfícies de ataque do projeto. Atividades: Aplicação prática da metodologia de Modelagem de Ameaças (Threat Modeling) diretamente sobre o diagrama arquitetural do projeto final. Os alunos utilizarão frameworks conceituados como o STRIDE para sistematizar a identificação de ameaças em cada componente isolado do sistema e criarão a Matriz de Riscos base, classificando os problemas conforme a probabilidade e o impacto severo. Data da aula: 22/10

"26/10 a 30/10": Semana 33 - PROJETO FINAL: Implementação de Criptografia Conteúdo: Aplicação de criptografia em repouso e em trânsito no código-fonte. Atividades: Fase de codificação intensiva (Hands-on) focada exclusivamente na implementação rigorosa dos controlos lógicos de proteção da aplicação. Os grupos deverão integrar de forma totalmente funcional os mecanismos de criptografia para dados em repouso (bases de dados) e dados em trânsito (rede), assegurando a proteção inviolável das passwords e a confidencialidade das comunicações internas. Data da aula: 29/10

"02/11 a 07/11": Semana 34 - PROJETO FINAL: Controles de Acesso e Autorização Conteúdo: Desenvolvimento dos módulos de login seguro e perfis de utilizador. Atividades: Continuidade do exigente ciclo de desenvolvimento do projeto integrador com o foco integral voltado para a camada de Autenticação e Autorização. As equipas irão desenvolver, testar

exaustivamente e auditar os módulos de login, o gerenciamento seguro de sessões, a emissão e validação de tokens JWT (se aplicável) e as restrições hierárquicas inflexíveis para o acesso às rotas protegidas. Data da aula: 05/11

"09/11 a 13/11": Semana 35 - PROJETO FINAL: Revisão de Código e Saneamento Conteúdo: Auditoria estática cruzada e higienização de entradas de utilizadores. Atividades: Fase crucial de controlo de qualidade e saneamento rigoroso de código do projeto final. Os alunos conduzirão minuciosas análises estáticas cruzadas entre os grupos (Peer Review) para garantir, sem margem para dúvidas, que todas as entradas de utilizadores estão a ser devidamente tratadas, escapadas e higienizadas, bloqueando assim de maneira preventiva vetores perigosos como SQLi e XSS. Data da aula: 12/11

"16/11 a 20/11": Semana 36 - PROJETO FINAL: Testes de Invasão Cruzados (Parte 1) Conteúdo: Execução da fase de Pentest (Red Team) nas aplicações dos colegas. Atividades: Início oficial do esperado período de auditoria dinâmica cruzada (Pentest). Cada equipa tentará ativamente invadir a aplicação web desenvolvida por outro grupo, atuando na posição ofensiva de Red Team. Esta etapa prática exige o emprego estratégico de scanners de vulnerabilidade, varreduras de rede agressivas e tentativas manuais de exploração lógica para tentar contornar os controlos. Data da aula: 19/11

"23/11 a 27/11": Semana 37 - PROJETO FINAL: Testes de Invasão Cruzados (Parte 2) Conteúdo: Documentação de PoC (Proof of Concept) e consolidação das falhas. Atividades: Continuidade implacável da fase de testes de intrusão, agora com foco cirúrgico no aprofundamento da exploração das falhas críticas inicialmente encontradas. As equipas deverão documentar evidências técnicas irrefutáveis (screenshots e logs do servidor) de cada vulnerabilidade explorada com sucesso, elaborando uma Prova de Conceito (PoC) que irá compor o exigente relatório formal de auditoria. Data da aula: 26/11

"30/11 a 04/12": Semana 38 - PROJETO FINAL: Patch, Correção e Mitigação de Falhas Conteúdo: Atuação como Blue Team para correção das vulnerabilidades apontadas. Atividades: Retorno estratégico ao papel defensivo de Blue Team/Desenvolvedores. Os grupos receberão os densos relatórios de auditoria produzidos pelos colegas na semana anterior e iniciarão uma verdadeira força-tarefa intensiva para analisar a fundo as provas de conceito, aplicar todos os patches de correção estruturais no código-fonte e fechar de vez as brechas de segurança reportadas. Data da aula: 03/12

"07/12 a 11/12": Semana 39 - PROJETO FINAL: Consolidação da Documentação Técnica Conteúdo: Formatação da Matriz de Riscos e do Guia de Práticas Seguras Adotadas. Atividades: Fase final de consolidação, revisão e compilação de toda a trajetória percorrida no projeto integrador. As equipas focarão os seus esforços na redação e formatação profissional do Guia de Práticas Seguras Adotadas, na atualização final da Matriz de Riscos (já num cenário pós-correção) e na organização primorosa dos relatórios técnicos para a iminente submissão documental. Data da aula: 10/12

"14/12 a 18/12": Semana 40 - PROJETO FINAL: Defesa e Apresentação do Software Seguro Conteúdo: Argumentação técnica e apresentação pública da resiliência do sistema. Atividades:

Grande apresentação e defesa pública do Projeto Final de Segurança perante o docente responsável e a restante turma. As equipas deverão demonstrar com eloquência a evolução do sistema, listar as vulnerabilidades críticas encontradas, explicar pormenorizadamente como